LEGAL · DATA PROCESSING AGREEMENT

Data Processing Agreement

Our commitments when we process your people's data for you: GDPR Article 28 terms, US service-provider terms, and four annexes (processing, security measures, sub-processors, SCC selections).

LAST UPDATED 2026-10-23

DOCUMENT	BREACH NOTICE	SUB-PROCESSOR NOTICE	TRANSFERS
DPA	Within 72 hours	30 days	SCCs Modules 2 and 3

Template, not legal advice; have counsel review it. It applies with the Terms of Service or a signed MSA, and either party can sign a copy on request. The processor is Truehound (a business being organized in the United States).

01 Definitions and scope

This DPA forms part of the agreement under which Customer uses Truehound (the Terms of Service, or a signed MSA and order form, the "Agreement"). Capitalised terms have the meaning given in the GDPR or the Agreement, with these additions:

Data Protection Law: the GDPR (Regulation (EU) 2016/679), the UK GDPR and Data Protection Act 2018, the Swiss Federal Act on Data Protection, and US state privacy laws such as the California Consumer Privacy Act (CCPA), each where it applies.

Personal Data: personal data that Truehound processes on Customer's behalf in providing the Access Audit and the related services (the "Services").

SCCs: the Standard Contractual Clauses of Commission Implementing Decision (EU) 2021/914. **UK Addendum**: the International Data Transfer Addendum issued by the UK Information Commissioner.

This DPA does not cover data Truehound controls for its own purposes (its website visitors, account sign-in and billing records); the Privacy Policy covers those.

02 Roles, instructions and duration

2.1 Roles. Customer is the Controller (or a Processor acting for its own Controller) and Truehound is its Processor (or sub-processor). For the CCPA, Truehound is Customer's service provider.

2.2 Instructions. Truehound processes Personal Data only on Customer's documented instructions: the Agreement, this DPA, and Customer's choices in the product (such as the apps an admin connects, the actions a person confirms, or agreeing to send facts to an AI feature), including for transfers, unless the law requires otherwise; in that case Truehound tells Customer first, unless the law forbids it.

2.3 Unlawful instructions. Truehound tells Customer promptly if it believes an instruction infringes Data Protection Law, and may suspend that processing until Customer confirms or changes it.

2.4 Customer's duties. Customer is responsible for having a lawful basis to connect its apps and process its people's data in Truehound, for telling its people about it, and for the accuracy of what it uploads (such as a leavers list).

2.5 Duration. This DPA lasts as long as Truehound processes Personal Data for Customer, and survives the Agreement until that data is deleted under section 9.

03 Confidentiality

3.1 Everyone Truehound authorises to process Personal Data is bound by confidentiality, and gets access only as far as the task needs. Today that is the founder alone (see Annex II).

3.2 No selling or other use. Truehound does not sell or share Personal Data, does not use it to train AI models, does not combine it with data from other customers or sources except as needed to provide the Services, and does not retain, use or disclose it for any purpose outside the Agreement, including outside the direct business relationship with Customer. Truehound will tell Customer if it can no longer meet these obligations.

04 Security of processing

4.1 Truehound applies the technical and organisational measures in Annex II, appropriate to the risk, and keeps them at least as protective for the term.

4.2 Truehound does not claim a third-party certification or attestation such as SOC 2 or ISO 27001; it has neither yet (the Trust Center shows the plan).

05 Sub-processors

5.1 Authorisation. Customer gives general written authorisation for the sub-processors listed in Annex III and on the public sub-processors page.

5.2 Notice and objection. Truehound emails Customer's account owners and billing contact at least 30 days before adding or replacing a sub-processor, and posts the change on the sub-processors page and its change feed. Customer may object in writing within that period on reasonable data protection grounds; the parties will discuss in good faith, and if Truehound cannot offer a reasonable alternative, Customer may terminate the affected Services and receive a refund of prepaid fees for the unused period.

5.3 Flow-down and responsibility. Truehound binds each sub-processor by written terms with data protection obligations at least as protective as this DPA, and remains fully liable to Customer for each sub-processor's performance of them.

06 Data subject requests and other assistance

6.1 Requests. Truehound forwards to Customer any request it receives from Customer's people about Personal Data within 5 business days, and does not answer it except on Customer's instruction or where the law requires. Taking into account the nature of the processing, Truehound helps Customer answer requests to access, correct, delete, restrict, object or port data: by the in-product tools (a JSON export of everything the workspace holds, exports of reports and tables, editing or removing entries, deletion of the workspace) and, on request, by doing it within 30 days and returning data as JSON or CSV.

6.2 Other assistance. Truehound gives Customer the information it reasonably needs for a data protection impact assessment, prior consultation with a supervisory authority, and its own security obligations (GDPR Articles 32 to 36), as far as it relates to the Services.

07 Personal data breaches

7.1 Notice. Truehound notifies Customer without undue delay, and within 72 hours, after becoming aware of a Personal Data Breach affecting Personal Data, by email to Customer's account owners and billing contact.

7.2 Content. The notice describes, as far as then known, the nature of the breach, the categories and approximate number of people and records affected, the likely consequences, the measures taken or proposed, and a contact. Truehound updates Customer as it learns more, takes reasonable steps to contain and remedy the breach, and does not notify Customer's people or regulators on Customer's behalf without Customer's agreement unless the law requires it.

7.3 A notice is not an admission of fault.

08 Deletion and return

8.1 Self-service. Customer can delete any workspace, and with it all Personal Data Truehound holds for it, at any time in the product. Data kept only in Customer's browsers is removed by Customer (sign out, disconnect, or clear site data).

8.2 At the end. On termination, or earlier on request to truehoundhq@truehound.io, Truehound returns Personal Data as JSON or CSV if asked, then deletes it within 30 days, and confirms deletion in writing on request. Copies in its database provider's point-in-time restore expire within 30 days after that. Truehound may keep only what the law requires it to keep, protected under this DPA.

09 Information and audits

9.1 Information. Truehound makes available the information needed to show compliance with GDPR Article 28 and this DPA: it answers reasonable security and privacy questionnaires, and shares its Trust Center, technical documentation and test results.

9.2 Audits. Where that is not enough, Customer (or an independent auditor it appoints, bound by confidentiality) may audit Truehound's compliance once in any 12 months, on 30 days' written notice, remotely or during business hours, in a way that does not expose other customers' data. Customer may also audit after a Personal Data Breach or where a supervisory authority requires it. Each party bears its own costs, unless the audit finds a material breach by Truehound.

10 International transfers

10.1 Truehound and its sub-processors process Personal Data in the United States and the other locations in Annex III. Truehound does not offer a choice of region yet.

10.2 Where Personal Data subject to the GDPR is transferred to Truehound in a country without an adequacy decision, the SCCs apply and are incorporated by reference, with the selections in Annex IV: Module Two where Customer is a Controller, Module Three where Customer is a Processor. For the UK GDPR the UK Addendum applies, and for Swiss data the SCCs apply with the amendments the Swiss authority requires. Onward transfers to sub-processors are covered by the SCCs or by the sub-processor's participation in the EU-US Data Privacy Framework, as Annex III states.

11 Liability and precedence

11.1 The Agreement's limits of liability apply to this DPA. Nothing limits liability owed to people under GDPR Article 82 or that the law does not allow to be limited.

11.2 If documents conflict, this order applies: the SCCs, then this DPA, then the Agreement.

12 Annex I: Description of processing

Parties. Data exporter: Customer, as named in the Agreement, Controller. Data importer: Truehound (a business being organized in the United States), Processor, contact truehoundhq@truehound.io.

Data subjects. Customer's users of Truehound; the people in Customer's GitHub organization and connected apps (employees, contractors, outside collaborators, former staff); people named in Customer's leavers list, access requests, reviews and HR feed.

Categories of Personal Data. Identifiers and work details: name, work email, username or login, app account ids, role, department, title, manager, start and leaving dates. Access data: accounts and their status, roles, groups, repository and app grants, two-factor status, last sign-in or activity, deploy key titles and dates. Discovery data, only where switched on: the apps a person signed in to (registered domain and time, from the browser extension), the sender domain, subject and date of sign-up and invoice emails (mailbox metadata, never bodies), and software charges (vendor, amount, date). Records of Customer's actions: approvals, decisions and the Proof log. Credentials an admin saves for connected apps (encrypted).

Sensitive data. None intended. The Services do not read pay, health, bank or other special category fields, and Customer will not upload them.

Nature and purpose. Reading the connected apps, finding access that should be removed or reviewed, showing it to Customer, running the changes and reviews a person confirms, keeping evidence of them, and, only if AI is switched on, sending the facts of one request, or of an access review the agent drafts on its schedule (which an admin can turn off), to an AI model for a draft that a person approves.

Frequency. Continuous while Customer uses the Services: on each scan, request, review and action, and on the scheduled re-scans of a watched organization.

Retention. As in the Privacy Policy's retention table: scan history 90 days (latest kept), extension sign-ins 395 days, the rest until Customer deletes it or the workspace, then deleted under section 8.

13 Annex II: Technical and organisational measures

MEASURE	HOW TRUEHOUND DOES IT
Minimisation	Read-only access first; only people, accounts, roles, status, dates and grants are read; no message, document or email body contents; mailbox access limited to gmail.metadata and Mail.ReadBasic; secret values masked and never kept; webhook addresses reduced to their host; without an account, data stays in Customer's browser
Encryption in transit	HTTPS (TLS) for the site, the connector, the API and every provider call
Encryption at rest	Saved app credentials, including one-click app sign-ins, encrypted with AES-256-GCM under a key derived per workspace (HKDF-SHA256) from a master secret held only in the connector's secret store, bound to their workspace and app, with key rotation; sign-in links, sessions, invites, extension and webhook tokens stored only as SHA-256 hashes; the database provider encrypts stored data at rest
Access control	Per-workspace isolation on every query (a non-member gets not found), owner, admin and member roles, CSRF tokens and an origin allowlist on the API, an HttpOnly Secure session cookie; production access limited to the founder
Integrity and evidence	The Proof log: every change, approval and consent sealed in a SHA-256 hash chain, so an edit or deletion shows
Change control	A change in a connected app runs only after a person confirms it; an approval policy can require a second admin
Secure development	Code review by the founder, automated type checks, linting and tests before every push, dependency lockfiles, a strict Content Security Policy
Abuse limits	Rate limits on sign-in, forms, relays and AI requests; IP addresses used for limits are kept in memory or stored only as hashes
Backups	Database point-in-time restore by the provider, up to 30 days
Incidents	Breach notice within 72 hours; vulnerability reports through the disclosure policy at /security-disclosure

14 Annex III: Sub-processors

SUB-PROCESSOR	PURPOSE	LOCATION	TRANSFER SAFEGUARD	WHEN
GitHub (GitHub Pages) (GitHub, Inc.)	Hosts the truehound.io website and app files.	United States, served through a global content network	Participates in the EU-US Data Privacy Framework, with the UK and Swiss extensions	Every visit
Cloudflare (Cloudflare, Inc.)	Runs Truehound's connector (a Cloudflare Worker): confirms payments, relays GitHub search and app API calls without storing tokens, and stores demo-form leads, report-email requests, public Truth Scan reports and, once accounts are on, account workspaces in Cloudflare D1.	Cloudflare's global network	Participates in the EU-US Data Privacy Framework; Standard Contractual Clauses in Cloudflare's DPA	Engaged when the connector features or accounts are used.
Stripe (Stripe, Inc. and Stripe, LLC)	Checkout, subscriptions, receipts and billing records.	United States and other countries where Stripe operates	Participates in the EU-US Data Privacy Framework; Standard Contractual Clauses in Stripe's DPA	Engaged when the customer pays.
Resend (Plus Five Five, Inc. (Resend))	Delivers account email: sign-in links, invites, alerts and the weekly digest an admin turns on, approval and task requests, and review reminders.	United States	Participates in the EU-US Data Privacy Framework; Standard Contractual Clauses in Resend's DPA	Only once accounts and account email are switched on.

SUB-PROCESSOR	PURPOSE	LOCATION	TRANSFER SAFEGUARD	WHEN
Anthropic (Anthropic, PBC)	The AI model (Claude) behind the optional AI features, such as Ask Truehound, Draft with AI and the agent's access-review drafts.	United States	Standard Contractual Clauses in Anthropic's DPA (Anthropic does not list the Data Privacy Framework)	Only if AI is switched on: when a person uses an AI feature, or, with an account, for the agent's scheduled review drafts, which an admin can turn off.
PostHog (PostHog, Inc.)	Product analytics.	United States, or the EU when an EU host is configured	Standard Contractual Clauses in PostHog's DPA	Only if enabled for a build. Not enabled on truehound.io.
Microsoft (Azure Bot Service) (Microsoft Corporation)	Delivers access-review messages and cards to Microsoft Teams.	United States and other countries where Microsoft operates	Participates in the EU-US Data Privacy Framework; Standard Contractual Clauses in Microsoft's DPA	Only if an admin connects Microsoft Teams for access reviews.
Finch (Finch (San Francisco, California))	Reads the employee list from an HR or payroll system for joiners and leavers, when an admin connects that system through Finch.	United States	Participates in the EU-US Data Privacy Framework, with the UK and Swiss extensions	Only if an admin connects an HR system through Finch.
Merge (Merge API, Inc.)	Reads the employee list from an HR system for joiners and leavers, when an admin connects that system through Merge.	United States, or the EU or Asia-Pacific region an admin picks	Standard Contractual Clauses in Merge's DPA	Only if switched on for the deployment and an admin connects an HR system through Merge.

SUB-PROCESSOR	PURPOSE	LOCATION	TRANSFER SAFEGUARD	WHEN
Kombo (Kombo Technologies GmbH)	Reads the employee list from an HR system for joiners and leavers, when an admin connects that system through Kombo.	European Union (Germany)	In the EU; transfers to Truehound in the United States are covered by our DPA's Standard Contractual Clauses	Only if switched on for the deployment and an admin connects an HR system through Kombo.

The current list, with change history and a change feed, is on the sub-processors page.

---

15 Annex IV: SCC selections

Selections. Modules Two and Three as section 10.2 says. Clause 7 (docking) included. Clause 9 Option 2, general written authorisation, with 30 days' notice. Clause 11 optional language not used. Clause 13: the supervisory authority of the EU member state where Customer is established, or where its representative is. Clauses 17 and 18: the law and courts of Ireland. UK Addendum: Tables 1 to 3 completed from this DPA; either party may end it as its section 19 allows.